

SMTP — Simple Mail Transfer Protocol

Servicio

SMTP (Simple Mail Transfer Protocol)

Puerto por defecto

25/TCP (SMTP entre servidores) · 587/TCP (submission con autenticación) · 465/TCP (SMTPS — SMTP sobre TLS implícito, legacy)

Descripción

SMTP es el protocolo estándar para el envío y retransmisión de correo electrónico en Internet. Definido originalmente en RFC 821 (1982) y actualizado en RFC 5321 (2008), establece cómo los agentes de transferencia de mensajes (MTA) se comunican para entregar correos de origen a destino. El puerto 25 se usa para comunicación entre servidores MTA; el puerto 587 es el estándar actual para envío autenticado de usuarios finales. Sin configuraciones adicionales (SPF, DKIM, DMARC), SMTP es susceptible a suplantación de identidad.

Riesgos de seguridad

- **Open Relay:** Un servidor SMTP mal configurado acepta y retransmite correos de cualquier origen hacia cualquier destino, siendo abusado para enviar spam y phishing masivo.
- **Email Spoofing:** Sin SPF y DKIM, cualquier actor puede enviar correos que aparenten provenir de un dominio legítimo.
- **Phishing:** Correos falsificados que imitan comunicaciones de bancos, proveedores o ejecutivos para engañar a usuarios y robar credenciales.
- **SMTP User Enumeration:** Comandos VRFY y EXPN habilitados permiten a atacantes enumerar usuarios válidos en el servidor.
- **Transmisión sin cifrado:** Sin STARTTLS, los correos viajan en texto plano entre servidores, susceptibles a interceptación.
- **Spam relay y blacklisting:** Un servidor comprometido o mal configurado que envía spam es incluido en listas negras (RBLs), afectando la entregabilidad de todos los correos legítimos del dominio.
- **Credential brute force:** El puerto 587 con autenticación débil puede ser atacado por fuerza bruta para obtener cuentas de correo válidas.

Escenarios de ataque

1. **Open Relay para spam masivo:** El atacante detecta un servidor SMTP sin autenticación que acepta correos de cualquier origen. Lo usa para enviar millones de correos de phishing aprovechando la reputación del servidor.

2. **Business Email Compromise (BEC):** El atacante falsifica el campo **From:** de un ejecutivo (sin DMARC: reject) y envía órdenes de transferencia bancaria fraudulentas al departamento financiero.
3. **SMTP VRFY enumeration:** El atacante ejecuta `VRFY usuario@empresa.com` para identificar qué cuentas de correo existen antes de lanzar un ataque de phishing dirigido (spear phishing).
4. **Credential stuffing en puerto 587:** Usando listas de credenciales filtradas, el atacante prueba combinaciones hasta obtener acceso a una cuenta de correo corporativa, usándola para phishing interno.
5. **STARTTLS downgrade:** Un atacante en posición de red intermedia quita el comando STARTTLS de la negociación SMTP, forzando la transmisión del correo en texto plano.

Mitigaciones recomendadas

- **Deshabilitar Open Relay:** Configurar el servidor para solo aceptar correos de dominios/IPs autorizados (mynetworks en Postfix).
- Implementar **SPF (Sender Policy Framework):** Registro DNS TXT que especifica qué servidores pueden enviar correo en nombre del dominio.
- Implementar **DKIM (DomainKeys Identified Mail):** Firma criptográfica de los correos para verificar autenticidad del remitente.
- Implementar **DMARC (Domain-based Message Authentication, Reporting & Conformance):** Política que indica qué hacer con correos que fallan SPF/DKIM (p=reject).
- Habilitar **STARTTLS** y preferiblemente **MTA-STS** para forzar cifrado TLS entre servidores.
- Deshabilitar los comandos VRFY y EXPN para prevenir enumeración de usuarios.
- Usar el puerto **587 con autenticación obligatoria** (SASL) para envío de usuarios finales; bloquear el 25 para tráfico de clientes.
- Implementar **rate limiting** y **greylisting** para reducir spam.
- Monitorear el servidor en **RBLs** (Spamhaus, Barracuda) y configurar alertas si el servidor es listado.

Nivel de exposición

Alto (si actúa como open relay o carece de SPF/DKIM/DMARC)

Referencias

- Klensin, J. *RFC 5321 — Simple Mail Transfer Protocol*. IETF, 2008. <https://www.rfc-editor.org/rfc/rfc5321>
- OWASP. *Email Security Best Practices*. <https://owasp.org>

- CISA. *Email Security Best Practices*. <https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-183a>
- NIST. *SP 800-177 Rev. 1 — Trustworthy Email*.
<https://csrc.nist.gov/publications/detail/sp/800-177/rev-1/final>